

Investigación: Sesgos Cognitivos en Ciberseguridad

¿Qué son los Sesgos Cognitivos?

Los sesgos cognitivos son atajos mentales (conocidos como heurísticas) que el cerebro utiliza para procesar información rápidamente y simplificar la toma de decisiones. Si bien desde una perspectiva evolutiva fueron mecanismos útiles para reaccionar ante peligros inmediatos, en entornos lógicos y complejos producen desviaciones sistemáticas del juicio racional. En lugar de evaluar la evidencia de manera objetiva, el cerebro filtra la información basándose en experiencias previas, emociones o expectativas, lo que da lugar a interpretaciones distorsionadas de la realidad.

¿Cómo influyen en las decisiones de ciberseguridad?

En el ámbito de la seguridad de la información, los sesgos cognitivos representan el eslabón más débil de la cadena, siendo explotados sistemáticamente por cibercriminales y actores de amenazas (APTs). Su influencia afecta a dos frentes críticos:

1. **Vulnerabilidad del usuario frente a la Ingeniería Social:** Los atacantes diseñan sus campañas (phishing, vishing, baiting) no para vulnerar el software, sino para activar emociones primarias —como la urgencia, el miedo, la codicia o la curiosidad— que "apagan" el pensamiento analítico del usuario y lo empujan a tomar decisiones automáticas y perjudiciales.
2. **Errores en el diseño de infraestructura y respuesta a incidentes:** A nivel técnico, afectan a los propios defensores y arquitectos de red. Un sesgo puede provocar que un analista de un SOC (Security Operations Center) ignore anomalías críticas en los logs de tráfico, que se diseñen topologías de red con políticas de seguridad laxas, o que se implementen controles insuficientes al sobreestimar las capacidades del equipo.

5 Ejemplos de Sesgos Cognitivos en Ciberseguridad

1. Sesgo de Confirmación (Confirmation Bias)

- **El concepto:** La tendencia a buscar, interpretar y recordar únicamente la información que confirme nuestras creencias o hipótesis preexistentes, ignorando los datos que las contradicen.
- **En Ciberseguridad:** Durante una investigación de respuesta a incidentes (*Incident Response*) o un análisis de cacería de amenazas (*Threat Hunting*), un analista puede asumir prematuramente que una alerta del SIEM es un simple "falso positivo" provocado por una mala configuración. Al revisar los logs, el analista solo buscará evidencias que corroboren que es un error del sistema, pasando por alto indicadores de compromiso (IoC) reales que sugieren una intrusión activa.

2. Efecto de Autoridad (Authority Bias)

- **El concepto:** La inclinación a confiar, obedecer y no cuestionar las instrucciones provenientes de figuras que se perciben con un alto nivel de autoridad.
- **En Ciberseguridad:** Es el núcleo de los ataques *BEC* (*Business Email Compromise*) y el *Spear Phishing*. Si un administrador junior de infraestructura recibe un correo urgente que parece provenir del CEO de la empresa, exigiendo acceso inmediato a un servidor o una transferencia de fondos, el respeto instintivo a la jerarquía suele provocar que se salte los protocolos de verificación estándar.

3. Sesgo de Optimismo o Ilusión de Invulnerabilidad (Optimism Bias)

- **El concepto:** La creencia injustificada de que uno mismo o la propia organización tiene muchas menos probabilidades de experimentar un evento negativo en comparación con los demás.
- **En Ciberseguridad:** Se manifiesta en la peligrosa mentalidad de "nuestra red no es un objetivo interesante para los atacantes" o "eso a nosotros no nos va a pasar". Este sesgo lleva a una subestimación crítica del riesgo en las evaluaciones, resultando en presupuestos deficientes, falta

de segmentación en la red (dejando todo en una VLAN plana) o desinterés por migrar hacia modelos *Zero Trust*.

4. Sesgo de Anclaje (Anchoring Bias)

- **El concepto:** La tendencia cognitiva a depender en exceso de la primera pieza de información que se recibe (el "ancla") a la hora de tomar decisiones futuras, dificultando el ajuste de perspectiva ante nuevos datos.
- **En Ciberseguridad:** En medio de una brecha de seguridad, los equipos de defensa pueden "anclarse" en el primer vector de ataque que descubren (por ejemplo, un servicio RDP expuesto). Todo el esfuerzo de remediación se concentra exclusivamente allí, ignorando que el atacante pudo haber establecido persistencia a través de otros métodos secundarios, dejando puertas traseras activas en la infraestructura.

5. Efecto Dunning-Kruger (Exceso de Confianza)

- **El concepto:** Un sesgo donde individuos con habilidades limitadas o conocimiento superficial en un área específica sobrestiman drásticamente su propia competencia.
- **En Ciberseguridad:** Puede ocurrir a todos los niveles. Un usuario estándar puede creer que es demasiado "listo" para caer en una suplantación de identidad. A nivel técnico, ocurre cuando se despliegan configuraciones complejas —como las reglas de un firewall perimetral o un enrutamiento OSPF— y se asume que la red está completamente blindada sin comprender realmente la superficie de ataque que se acaba de exponer, dejando vulnerabilidades críticas en el diseño.